Light

Cyber Security — Prevention

Over **1,100,000+ marks** of exam-aligned content across **67 qualifications**. 4,200+ auto-marked assessments & long-answer practice. No login required.

Assessment Hub | Notes / Textbook | Long-Answer Practice

Assessment Hub
Long-Answer
Notes Index
What you must know
Toolkit
1. Access control and physical security
2. Technical protection measures
3. Testing and policies
Worked examples
Quick reference
Typical pitfalls

Edexcel GCSE Computer Science — **Cyber Security Prevention (1CP2/01 Topics 4 & 5)**. This topic covers how organisations protect their networks and data from cyber threats, including access control, physical security, firewalls, anti-malware software, encryption, backups, penetration testing, ethical hacking, and acceptable use policies. Exam questions typically ask you to **describe** security measures, **explain** how they protect against threats, and **evaluate** their effectiveness. The 2024 Paper 1 included questions on penetration testing and anti-virus software processes. Expect questions worth 2—6 marks requiring you to link protection measures to specific threats.

Why cyber security prevention matters

Cyber attacks cost organisations billions of pounds each year. Understanding how to prevent attacks is essential:

- **Data protection:** Personal and financial data must be kept secure from unauthorised access
- **Business continuity:** Attacks can shut down systems and disrupt operations

- **Legal compliance:** Organisations must protect data under laws like the Data Protection Act
- **Reputation:** Security breaches damage trust and can destroy businesses
- **Exam relevance:** This topic spans Topics 4 and 5, typically worth 6—10 marks across Paper 1

What you must know

This checklist covers the key exam-visible concepts from Edexcel 1CP2 Topics 4 and 5 relating to cyber security prevention.

- **Describe** access control methods including usernames, passwords, and access levels/permissions
- **Describe** physical security measures such as locks, CCTV, and biometric access
- **Explain** how firewalls protect networks by filtering traffic
- **Describe** how anti-malware software detects and removes threats
- **Explain** the purpose of encryption in protecting data
- **Describe** backup strategies and why they are important
- **Define** penetration testing and explain its purpose
- **Explain** what ethical hacking is and how it differs from malicious hacking
- **Describe** the purpose and contents of an Acceptable Use Policy (AUP)

> **Specification link:** This topic covers Edexcel 1CP2 Paper 1 Topic 4 (network security: penetration testing, ethical hacking, access control, physical security, firewalls) and Topic 5 (protections: anti-malware, encryption, AUPs, backup).

Toolkit

These are the key definitions, protection measures, and patterns you need for exam questions about cyber security prevention.

Protection measures at a glance

Protection measure	What it does	Protects against
Access control	Restricts who can access systems and data	Unauthorised access, data theft
Physical security	Prevents physical access to hardware	Theft, tampering, unauthorised access
Firewall	Filters network traffic based on rules	Unauthorised network access, some malware
Anti-malware	Detects and removes malicious software	Viruses, worms, Trojans, ransomware
Encryption	Scrambles data so only authorised users can read it	Data interception, unauthorised reading

Protection measure	What it does	Protects against
Backup	Creates copies of data for recovery	Data loss from attacks, failure, or accidents
Penetration testing	Authorised testing to find vulnerabilities	Unknown security weaknesses
AUP	Rules for acceptable system use	Misuse, risky behaviour by users

Key definitions

Penetration testing

An authorised, simulated attack on a computer system carried out with the organisation's knowledge, to identify vulnerabilities and recommend security improvements.
Key phrase: "Authorised attack to find and fix weaknesses."

Ethical hacking

Legally breaking into computers and devices to test an organisation's defences. Ethical hackers use the same techniques as malicious hackers but have permission and report vulnerabilities rather than exploiting them.
Key phrase: "Legal hacking with permission to improve security."

Defence in depth

Organisations use multiple layers of protection — if one layer fails, others still provide security:

```
┌──────────────────────────────────────────────────────────────┐ │ POLICIES
AND TRAINING │ │ (AUPs, security awareness training) │
├──────────────────────────────────────────────────────────────┤ │ PHYSICAL
SECURITY │ │ (Locks, CCTV, biometrics, secure rooms) │
├──────────────────────────────────────────────────────────────┤ │ NETWORK
SECURITY │ │ (Firewalls, encryption) │
├──────────────────────────────────────────────────────────────┤ │ ACCESS
CONTROL │ │ (Usernames, passwords, permissions) │
├──────────────────────────────────────────────────────────────┤ │ SOFTWARE
PROTECTION │ │ (Anti-malware, updates, patches) │
├──────────────────────────────────────────────────────────────┤ │ DATA
PROTECTION │ │ (Encryption, backups) │
└──────────────────────────────────────────────────────────────┘ DATA
```

Matching threats to protections

Different security measures protect against different types of threats. Knowing which measure to recommend for a given scenario is a key exam skill:

If the scenario mentions...	Consider recommending...
Viruses, malware, infected files	Anti-malware software, regular scans, updates
Hackers, unauthorised access from outside	Firewall, strong passwords, access controls
Data sent over the internet, interception	Encryption
Ransomware, data loss, hardware failure	Regular backups (off-site)
Theft of computers or equipment	Physical security, encryption
Staff misusing systems	AUP, access controls, training
Finding security weaknesses	Penetration testing, ethical hacking

1. Access control and physical security

The first line of defence is controlling who can access systems and the physical hardware. These measures prevent unauthorised users from reaching systems or data in the first place.

1.1 Access control

Access control restricts who can use a system and what they can do with it. This prevents unauthorised users from accessing sensitive data or systems.

Usernames and passwords

The most common form of access control:

- **Username:** Identifies who is trying to access the system
- **Password:** Authenticates that the user is who they claim to be
- The combination proves the user's identity before granting access

Strong password requirements

Weak passwords are easy to guess or crack. Strong passwords should:

- Be at least 8 characters long (longer is better)
- Include uppercase and lowercase letters
- Include numbers and special characters
- Not be dictionary words or personal information
- Be unique for each account
- Be changed regularly

> **Exam tip:** When asked about password security, mention specific characteristics: length, mixed case, numbers, special characters, and regular changes.

Access levels and permissions

Different users need different levels of access. Organisations assign permissions based on job roles:

Access level	Typical permissions
Administrator	Full access — can change settings, add users, access all files
Standard user	Can use applications and access own files, limited settings
Guest	Very limited access — may only view certain files
Read-only	Can view files but cannot modify or delete them

Principle of least privilege: Users should only have the minimum access needed to do their job. This limits the damage if an account is compromised.

Other authentication methods

- **Two-factor authentication (2FA):** Requires two forms of verification (e.g., password + code sent to phone)
- **Biometrics:** Uses physical characteristics like fingerprints or facial recognition
- **Security questions:** Additional verification using personal information

Why multiple authentication factors matter

Single-factor authentication (just a password) has weaknesses — passwords can be guessed, stolen, or cracked. Two-factor authentication adds a second layer:

- **Something you know:** Password, PIN, security question
- **Something you have:** Phone (for codes), security token, smart card
- **Something you are:** Fingerprint, face, iris (biometrics)

An attacker would need to compromise both factors to gain access, making unauthorised access much more difficult.

1.2 Physical security

Physical security protects the actual hardware — servers, computers, network equipment, and storage devices. Even the best software security is useless if someone can simply walk off with a hard drive.

Locks and barriers

- Locked server rooms
- Locked cabinets for equipment
- Security doors with keypads or card readers
- Cable locks for laptops

Surveillance

- CCTV cameras
- Security guards
- Motion sensors
- Intruder alarms

Biometric access

- Fingerprint scanners
- Facial recognition
- Iris/retina scanners
- Voice recognition

Why physical security matters

Without physical security, attackers could:

- Steal computers or storage devices containing sensitive data
- Install malware directly onto systems
- Connect unauthorised devices to the network
- Damage or destroy equipment
- Access systems that have been left logged in

Physical security scenarios

Consider these real-world examples of why physical security is important:

Scenario	Risk without physical security	Protection measure
Server containing customer database	Thief could steal hard drives with all customer data	Locked server room, access logging
Reception area with computers	Visitor could plug in USB device with malware	Staff supervision, disable USB ports
Office after hours	Break-in could result in equipment theft	Alarm system, CCTV, security patrols
Data centre	Unauthorised access could cause massive breach	Biometric access, security guards, mantrap doors

Worked Example 1 – Describing access control

Question: Describe two ways a company can use access control to protect its data. [4 marks]

Model answer:
Method 1 — Usernames and passwords:
Users must enter a username and password to log in to the system **(1)**.
This authenticates their identity and prevents unauthorised users from accessing the system **(1)**.
Method 2 — Access levels/permissions:
Different users are given different permissions based on their job role **(1)**.
This means users can only access the data they need for their work, limiting the damage if an account is compromised **(1)**.

Exam tip: For "describe" questions, name the method and then explain what it does or why it helps security.

Worked Example 2 – Explaining password security

Question: State two characteristics of a strong password. [2 marks]

Model answer:
Contains a mix of uppercase and lowercase letters **(1)**.
Is at least 8 characters long **(1)**.
Also acceptable: Contains numbers / Contains special characters / Is not a dictionary word / Is changed regularly / Is unique for each account

Exam tip: "State" means brief answers. Give two distinct characteristics — don't just say "it should be complex."

Worked Example 3 — Physical security measures

Question: A company stores sensitive data on servers in an office building. Describe two physical security measures the company should use. [4 marks]

Model answer:
Measure 1 — Locked server room:
The servers should be kept in a locked room with restricted access **(1)**.
Only authorised IT staff should have keys or access codes, preventing others from physically accessing the servers **(1)**.
Measure 2 — CCTV cameras:
Security cameras should monitor the server room and entrance points **(1)**.
This deters intruders and provides evidence if a security breach occurs **(1)**.

Exam tip: Link physical security measures to what they prevent — theft, unauthorised access, or evidence gathering.

Worked Example 4 — Access levels scenario

Question: Explain why a hospital should give different access levels to doctors, receptionists, and IT administrators. [3 marks]

Model answer:
Different staff members need access to different information to do their jobs **(1)**.
Doctors need access to patient medical records but receptionists only need contact details and appointment information **(1)**.
Restricting access to only what each role needs reduces the risk of data being accessed inappropriately or accidentally modified **(1)**.

Exam tip: Use the scenario given. Apply the concept of "least privilege" —

users only get access they need for their specific role.

2. Technical protection measures

Technical protection measures use hardware and software to defend against cyber threats. These include firewalls, anti-malware software, encryption, and backups.

2.1 Firewalls

A **firewall** is a security system that monitors and controls network traffic based on predetermined security rules. It acts as a barrier between a trusted internal network and untrusted external networks like the internet.

How firewalls work

- Examines all incoming and outgoing network traffic
- Compares traffic against a set of rules
- Allows permitted traffic to pass through
- Blocks traffic that violates the rules

What firewalls can block

- Unauthorised access attempts from outside the network
- Suspicious traffic patterns that may indicate an attack
- Connections to known malicious websites or IP addresses
- Traffic on ports that should not be in use

Firewall types:

- **Hardware firewall:** A physical device between the network and the internet
- **Software firewall:** A program running on a computer

Many organisations use both for extra protection.

Firewall limitations

While firewalls are essential, they have limitations:

- Cannot detect malware inside files — only anti-malware can do this
- Cannot protect against attacks from inside the network
- Cannot prevent social engineering attacks
- Must be properly configured — incorrect rules create vulnerabilities
- Cannot stop authorised users from making mistakes

Exam tip: A firewall filters traffic but does not scan for viruses — that's the job of anti-malware software. Don't confuse them.

2.2 Anti-malware software

Anti-malware software (including antivirus programs) detects, prevents, and removes malicious software from computer systems.

How anti-malware works

Anti-malware software typically uses several methods:

- **Signature-based detection:** Compares files against a database of known malware signatures
- **Behavioural detection:** Monitors programs for suspicious activity
- **Real-time scanning:** Checks files as they are opened or downloaded

- **Full system scans:** Periodically checks all files on the system

Anti-virus process

The 2024 exam asked about how anti-virus software works:

1. Load virus signature database
2. Scan target file and compare against signatures
3. Decide if a virus has been detected
4. If detected: quarantine, fix, or delete the file
5. If not detected: no action required

> **Exam tip:** Anti-malware must be kept up to date — new malware is created constantly, and the signature database needs updating to detect it.

Anti-malware actions

When malware is detected, the software can take several actions:

- **Quarantine:** Isolate the infected file so it cannot harm the system, while keeping it for analysis
- **Delete:** Remove the infected file completely
- **Repair/Clean:** Attempt to remove the malicious code while keeping the original file
- **Alert:** Notify the user or system administrator

Quarantine is often preferred over immediate deletion because it allows recovery if a file is falsely identified as malware.

2.3 Encryption

Encryption converts readable data (plaintext) into an unreadable format (ciphertext) using a mathematical algorithm and a key. Only someone with the correct key can decrypt and read the data.

How encryption protects data

- **Data in transit:** Protects data as it travels across networks (e.g., HTTPS, email encryption)
- **Data at rest:** Protects stored data (e.g., encrypted hard drives, encrypted files)

Even if encrypted data is intercepted or stolen, it cannot be read without the decryption key.

Common uses of encryption

- Online banking and shopping (HTTPS)
- Email communication
- Stored passwords
- Full disk encryption on laptops
- Wireless network security
- Protecting sensitive files

```
ENCRYPTION PROCESS: Original data Encrypted data Decrypted data (Plaintext)
(Ciphertext) (Plaintext) "Password123" ──► "x8#kL@9mQ2$p" ──►
```

```
"Password123" | | ENCRYPT DECRYPT (with key) (with key) Without the correct
key, encrypted data cannot be read.
```

Why encryption is essential

Encryption is one of the most important security measures for protecting sensitive data:

- **Legal compliance:** Data protection laws often require encryption for personal data
- **Laptop theft:** If an encrypted laptop is stolen, the data cannot be accessed
- **Network security:** HTTPS encryption protects online transactions
- **Email privacy:** Encrypted email cannot be read if intercepted
- **Cloud storage:** Encrypting files before uploading protects them even if the cloud provider is breached

> **Key point:** Encryption does not prevent data from being stolen or intercepted — it prevents stolen data from being **read**. The data is still taken, but it is useless without the decryption key.

2.4 Backups

Backups are copies of data stored separately from the original. If data is lost, corrupted, or encrypted by ransomware, it can be restored from the backup.

Why backups are essential

Backups protect against data loss from:

- **Ransomware attacks:** If data is encrypted by attackers, you can restore from backup instead of paying
- **Hardware failure:** Hard drives fail eventually
- **Accidental deletion:** Users sometimes delete important files by mistake
- **Natural disasters:** Fire, flood, or theft can destroy equipment
- **Malware:** Some malware deletes or corrupts files

Types of backup

Backup type	What it backs up	Advantage
Full backup	All selected files	Complete copy, easy to restore
Incremental	Only files changed since last backup	Faster, uses less storage
Differential	Files changed since last full backup	Faster restore than incremental

Backup best practices

- **Regular backups:** Daily or more frequent for important data
- **Multiple copies:** Keep more than one backup
- **Off-site storage:** Keep at least one backup in a different physical location
- **Test restores:** Regularly check that backups can actually be restored
- **Encrypted backups:** Protect backup data with encryption

> **The 3-2-1 rule:**
> - **3** copies of your data
> - **2** different storage types

- **1** copy off-site

2.5 Software updates and patches

Keeping software up to date is a critical but often overlooked security measure. Software vendors regularly release updates to fix security vulnerabilities.

Why updates matter

- **Security patches:** Fix known vulnerabilities that attackers could exploit
- **Bug fixes:** Correct errors that could be security risks
- **New threat protection:** Updates protect against recently discovered vulnerabilities

What should be updated

- Operating systems (Windows, macOS, Linux)
- Web browsers
- Anti-malware software and definitions
- Applications (office software, media players)
- Firmware on network devices

Many cyber attacks exploit known vulnerabilities that have already been patched — but the victim had not installed the update. Keeping systems up to date is one of the simplest and most effective security measures.

Exam tip: When discussing anti-malware protection, always mention that the software and its virus definitions must be kept up to date to detect new threats.

Worked Example 5 — Describing firewall function

Question: Describe how a firewall helps protect a network. [2 marks]

Model answer:
A firewall monitors all incoming and outgoing network traffic **(1)**.
It blocks traffic that does not meet security rules, preventing unauthorised access to the network **(1)**.

Exam tip: Focus on what firewalls do: monitor traffic and block based on rules. Don't say firewalls detect viruses — that's anti-malware.

Worked Example 6 — Anti-malware process

Question: Describe how anti-virus software detects malware on a computer. [3 marks]

Model answer:
The anti-virus software loads a database of known virus signatures **(1)**.
It scans files on the computer and compares them against the signature database **(1)**.
If a file matches a known virus signature, the software identifies it as infected and can quarantine or delete it **(1)**.

Exam tip: The 2024 exam asked this as a flowchart question. Know the steps: load signatures → scan/compare → decide → act (quarantine/delete if found).

Worked Example 7 — Explaining encryption

Question: Explain why a company should use encryption when employees send emails containing customer data. [2 marks]

Model answer:
Encryption converts the email content into an unreadable format during transmission **(1)**.
If the email is intercepted, the attacker cannot read the customer data without the decryption key **(1)**.

Exam tip: Always explain what encryption does (makes data unreadable) AND why that matters (protects against interception).

Worked Example 8 — Backup importance

Question: A school stores student records on a computer system. Explain why the school should make regular backups of this data. [3 marks]

Model answer:
Backups allow the school to restore data if the original is lost or damaged **(1)**.
If the system is infected with ransomware that encrypts files, the school can restore from backup instead of paying the ransom **(1)**.
Hardware can fail unexpectedly, and without backups the student records could be permanently lost **(1)**.

Exam tip: Give specific examples of why data might be lost: ransomware, hardware failure, accidental deletion, disasters.

3. Testing and policies

Technical measures alone are not enough. Organisations must also test their security and create policies that guide how users should behave. This section covers penetration testing, ethical hacking, and acceptable use policies.

3.1 Penetration testing

Penetration testing (pen testing) is an authorised, simulated cyber attack on a computer system, performed to evaluate the security of the system.

Key characteristics

- **Authorised:** Carried out with the organisation's knowledge and permission
- **Simulated attack:** Uses the same techniques as real attackers
- **Purpose:** To find vulnerabilities before malicious attackers do
- **Report:** Results in recommendations for improving security

What penetration testers look for

- Weak passwords
- Unpatched software vulnerabilities
- Misconfigured firewalls
- Insecure network services
- Social engineering vulnerabilities
- Physical security weaknesses

> **2024 exam definition:**
> "A network/system attack carried out with the knowledge of an organisation to recommend measures that should be taken to improve security."

Penetration testing process

A typical penetration test follows these stages:

1. **Planning:** Define scope and objectives with the organisation
2. **Reconnaissance:** Gather information about the target systems
3. **Scanning:** Identify potential vulnerabilities
4. **Exploitation:** Attempt to exploit vulnerabilities
5. **Reporting:** Document findings and recommend improvements

The organisation then uses this report to fix vulnerabilities before real attackers can exploit them.

3.2 Ethical hacking

Ethical hacking is the practice of legally breaking into computers and devices to test an organisation's defences. Ethical hackers are also called "white hat" hackers.

Ethical vs malicious hacking

Aspect	Ethical hacking	Malicious hacking
Permission	Has authorisation from the organisation	No permission — illegal
Intent	To improve security	To steal, damage, or disrupt
Reporting	Reports all vulnerabilities found	Exploits vulnerabilities
Legality	Legal (with contract)	Illegal

Why use ethical hackers?

- They think like attackers, so they find vulnerabilities that developers miss
- They test real-world attack scenarios
- They provide independent assessment of security
- Finding vulnerabilities before criminals do prevents breaches

3.3 Acceptable Use Policies (AUPs)

An **Acceptable Use Policy (AUP)** is a document that outlines the rules and guidelines for using an organisation's computer systems and network. It defines what users can and cannot do.

Typical AUP contents

- **Permitted uses:** What the system may be used for (work purposes, educational activities)
- **Prohibited activities:** What is not allowed (illegal downloads, personal business, offensive content)
- **Security requirements:** Password rules, not sharing login details, locking computers when away
- **Data handling:** Rules about storing and sharing sensitive data
- **Consequences:** What happens if the policy is violated (warnings, dismissal, legal action)
- **Monitoring:** Notice that activity may be monitored

Why AUPs are important

- **Set expectations:** Users know what is acceptable
- **Reduce risk:** Prevent risky behaviours that could compromise security
- **Legal protection:** Organisation can take action against violators
- **Compliance:** Help meet legal requirements for data protection
- **Awareness:** Make users think about security

> **Exam tip:** AUPs are about rules for users, not technical controls. They prevent misuse through policy rather than technology.

Example AUP rules

A school AUP might include rules such as:

Students must:

- Only use the network for educational purposes
- Keep passwords secret and not share accounts
- Report any security concerns to staff
- Log off when leaving a computer
- Respect copyright and not download illegal content

Students must not:

- Access inappropriate or offensive websites
- Attempt to bypass security controls
- Install software without permission
- Share or access other users' files without permission

- Use the network for commercial purposes

3.4 User training and awareness

Technical measures alone are not enough — users are often the weakest link in security. Training helps users recognise and avoid threats.

What training should cover

- Recognising phishing emails
- Creating and managing strong passwords
- Safe internet browsing habits
- Reporting suspicious activity
- Following the AUP

Why training matters

- Many attacks rely on tricking users
- Trained users spot threats others miss
- Reduces accidental security breaches
- Creates a security-aware culture
- Supports technical security measures

3.5 Evaluating security measures

Exam questions may ask you to evaluate which security measures are most appropriate for a given scenario. The key is to match the measure to the specific threat or concern mentioned in the question.

Consider the following when recommending security measures:

- **What is the threat?** Different threats require different protections
- **What data is at risk?** More sensitive data needs stronger protection
- **What is the budget?** Some measures are more expensive than others
- **What is practical?** The measure must be usable by staff

Threat/concern	Most appropriate measures
Malware infection	Anti-malware software, regular updates, user training
Unauthorised network access	Firewall, strong passwords, access controls
Data interception	Encryption
Data loss	Regular backups (including off-site)
Physical theft	Physical security (locks, CCTV), encryption
Unknown vulnerabilities	Penetration testing, ethical hacking
User misuse	AUP, training, access controls

Worked Example 9 — Defining penetration testing

Question: Describe what is meant by penetration testing. [2 marks]

Model answer:
Penetration testing is an authorised/simulated attack on a computer system **(1)**.
It is carried out with the organisation's knowledge to identify vulnerabilities and recommend security improvements **(1)**.

Exam tip: This was in the 2024 exam. Key points: authorised, simulated attack, to find weaknesses and improve security.

Worked Example 10 — Ethical vs malicious hacking

Question: Explain one difference between ethical hacking and malicious hacking. [2 marks]

Model answer:
Ethical hacking is carried out with the permission of the organisation **(1)**.
Malicious hacking is done without permission and is illegal **(1)**.
Also acceptable: Ethical hackers report vulnerabilities to help fix them / Malicious hackers exploit vulnerabilities for personal gain or to cause damage.

Exam tip: The key difference is permission/authorisation. Ethical hackers have it; malicious hackers do not.

Worked Example 11 — AUP purpose and contents

Question: A school has an Acceptable Use Policy (AUP) for students using school computers. Describe two things the AUP might include. [4 marks]

Model answer:
Content 1 — Prohibited activities:
The AUP might state that students must not access inappropriate websites or download copyrighted material **(1)**.
This prevents misuse of the network and protects the school from legal issues **(1)**.
Content 2 — Security requirements:
Students might be required to keep their passwords secret and not share login details **(1)**.
This helps maintain individual accountability and prevents unauthorised access **(1)**.

Exam tip: When describing AUP contents, give specific examples relevant to the scenario (school = appropriate content rules).

Worked Example 12 — Evaluating security measures

Question: A small business is concerned about protecting customer data. Explain two security measures the business should implement and why each is important. [6 marks]

Model answer:
Measure 1 — Encryption:
The business should encrypt customer data both when stored and when transmitted **(1)**.
This means if data is intercepted or stolen, it cannot be read without the decryption key **(1)**.
This protects customer privacy and helps the business comply with data protection laws **(1)**.
Measure 2 — Regular backups:
The business should make regular backups of customer data and store copies off-site **(1)**.
If data is lost due to ransomware, hardware failure, or disaster, it can be restored from backup **(1)**.
This ensures business continuity and prevents permanent loss of important customer records **(1)**.

Exam tip: For evaluation questions, explain what the measure does, how it protects data, and why this matters for the business.

Worked examples summary

The table below summarises the 12 worked examples covered in this topic, organised by section and difficulty level.

#	Topic	Question type	Marks	Key skill
1	Access control	Describe two methods	4	Usernames/passwords + permissions
2	Passwords	State characteristics	2	Strong password features
3	Physical security	Describe measures	4	Locks, CCTV, link to prevention
4	Access levels	Explain scenario	3	Least privilege principle

#	Topic	Question type	Marks	Key skill
5	Firewalls	Describe function	2	Monitor and filter traffic
6	Anti-malware	Describe process	3	Signatures, scan, detect, act
7	Encryption	Explain purpose	2	Unreadable without key
8	Backups	Explain importance	3	Restore from ransomware/failure
9	Penetration testing	Describe meaning	2	Authorised attack to find weaknesses
10	Ethical hacking	Explain difference	2	Permission vs no permission
11	AUP	Describe contents	4	Rules and requirements
12	Evaluation	Explain measures	6	Match measures to scenario

Quick reference

Key terms and definitions

Term	Definition (mark-scheme style)
Access control	Methods to restrict who can access a system and what they can do (usernames, passwords, permissions)
Physical security	Measures to prevent unauthorised physical access to hardware (locks, CCTV, biometrics)
Firewall	Hardware or software that monitors and filters network traffic based on security rules
Anti-malware	Software that detects, prevents, and removes malicious software from a system
Encryption	Converting data into an unreadable format that can only be read with the correct decryption key
Backup	A copy of data stored separately so it can be restored if the original is lost or damaged
Penetration testing	An authorised simulated attack to identify vulnerabilities and recommend security improvements
Ethical hacking	Legally breaking into systems with permission to test and improve security
AUP	Acceptable Use Policy — a document defining rules for using an organisation's computer systems

Term	Definition (mark-scheme style)
Authentication	Verifying that a user is who they claim to be (e.g., by checking their password)
Biometrics	Using physical characteristics (fingerprint, face, iris) to verify identity

Protection measures summary

Measure	What it does	Protects against
Strong passwords	Prevent guessing or cracking of login credentials	Unauthorised access
Access levels	Limit what each user can access	Data breach, insider threats
Locked rooms	Prevent physical access to hardware	Theft, tampering
CCTV	Monitor and record activity	Theft, provide evidence
Firewall	Filter network traffic	Unauthorised network access
Anti-malware	Detect and remove malware	Viruses, Trojans, ransomware
Encryption	Make data unreadable without key	Data interception, theft
Backups	Create copies for recovery	Data loss, ransomware
Penetration testing	Find vulnerabilities before attackers	Unknown weaknesses
AUP	Set rules for acceptable use	User misuse, risky behaviour

Anti-virus process steps

Step	Action
1	Load virus signature database
2	Scan target file
3	Compare file against known signatures
4	Decide if virus detected
5a	If detected: quarantine/delete file

Step	Action
5b	If not detected: no action required

Typical pitfalls

Pitfall 1 — Confusing firewalls and anti-malware.
Wrong: "A firewall scans for viruses."
Right: A firewall **filters network traffic**. Anti-malware software scans for and removes viruses. They are different tools.

Pitfall 2 — Vague password descriptions.
Wrong: "Use a strong password."
Right: Give specific features: "Use a password with at least 8 characters, including uppercase, lowercase, numbers, and special characters."

Pitfall 3 — Missing "authorised" for penetration testing.
Wrong: "Penetration testing is attacking a system to find weaknesses."
Right: Must include that it is **authorised** — done with the organisation's permission and knowledge.

Pitfall 4 — Saying encryption prevents interception.
Wrong: "Encryption stops data being intercepted."
Right: Encryption does not prevent interception — it **prevents intercepted data from being read**. The data can still be captured, but it will be unreadable.

Pitfall 5 — Forgetting off-site backups.
Wrong: "Make backups on the same computer."
Right: Backups should be stored **separately from the original**, ideally off-site, so a fire or theft doesn't destroy both.

Pitfall 6 — Confusing authentication and authorisation.
Wrong: Using these terms interchangeably.
Right: Authentication = proving who you are (username/password). **Authorisation** = what you're allowed to access (permissions).

Pitfall 7 — Thinking ethical hacking is illegal.
Wrong: "All hacking is illegal."
Right: Ethical hacking is legal because it is done **with permission**. Only hacking without permission is illegal.

Pitfall 8 — Generic AUP descriptions.
Wrong: "An AUP contains rules."
Right: Give specific examples: prohibited activities, password requirements, consequences for violations, acceptable use guidelines.

Pitfall 9 — Not linking measures to threats.
Wrong: Just listing security measures without explanation.
Right: Always explain **what** the measure protects against and **how** it provides that protection.

Pitfall 10 — Forgetting to update anti-malware.
Wrong: "Anti-malware software protects against all viruses."
Right: Anti-malware must be **kept up to date** because new malware is constantly created. Outdated software won't detect new threats.

Assessment Hub | Long-Answer | Notes Index

Williams Physics Education — over **1,100,000+ marks** of exam-aligned content and **4,200+ auto-marked assessments** across 67 qualifications at GCSE, A-Level, AP & Professional Qualifications. Free to use, no login required.

About & Contact • Privacy • Terms • Accessibility • Copyright • DMCA • YouTube

WPE is free for everyone. If our resources help you or your students, you can support the project here.

© 2026 Williams Physics Education. All rights reserved.